

Vulnerability Management Program

Asset ownership, scanning, prioritization, remediation SLAs, exceptions, and validation

Severity / context	Default SLA	Escalation
Critical - internet-facing or known exploited	7 days	Immediate owner notification; leadership visibility if missed
Critical - internal with compensating controls	14 days	Documented exception required if missed
High	30 days	Owner escalation at 75% of SLA
Medium	60 days	Track through normal remediation backlog
Low	90 days / risk-based	Bundle with maintenance where appropriate

Program Workflow

- Discover assets and assign technical/business owners.
- Scan authenticated where feasible and normalize findings.
- Prioritize using severity plus exploitability, exposure, privilege, asset criticality, data sensitivity, and compensating controls.
- Open remediation tasks with owner, due date, business context, and validation requirement.
- Escalate overdue high/critical findings.
- Retest before closure; do not close solely because a ticket says fixed.
- Track exceptions with owner, reason, compensating control, approval, and expiration date.

Management Metrics

Metric	90-day target
Internet-facing critical findings past SLA	0
Critical findings with named owner	100%
Mean days to remediate critical findings	<=7 days for internet-facing scope
Validated closure rate	100% of closed critical/high findings
Assets without recent authenticated scan	<5% of in-scope server assets
Expired exceptions still open	0